

DEVOPS MEETUP — ZERO TRUST · ISMS

~~ISMS가 사킨 게~~ 아니라, 우리가 필요했던 Zero Trust

— 물리 VPN을 해마다 다시 만난 정답까지, 6개월의 우회

구경열 ● 케이타운포유 ● AWSKRUG DEVOPS 22ND · 2026.06.17

접근통제가 사실상 없었다

× 백오피스가 전부 public — 도메인만 알면 누구나 접근

× MFA 미지원 — 인증 수단 자체가 없음

× 퇴사자 · 현직 구분 없이 접근 가능

× 개발본부 Client VPN — local DNS 이슈 반복

× 인증 수단이 파편화 — Identity Center로 통합을 시도했지만(DB · Datadog · Argo · Databricks · OpenSearch), OIDC 미지원으로 사내 자체 시스템은 Cognito 우회, GitHub · Miro · VDI는 결국 각자 따로. 통합도 사용자 관리도 불편했다.

VPN 대안을 찾다, 물리장비 없는 ZTNA 하나가 눈에 들어왔다

별도 HW 없이 동작하고 Zero Trust를 지원한다고 했다. 스펙도 제대로 모른 채 "한번 써보고 싶다" 정도의 호기심이었다. — 정답은 이미 여기 있었지만, 우리는 먼 길을 돌아간다.

ZTNA SaaS · 호기심

...

하지만 일단 보류

"ISMS면 폐쇄망 + 물리 VPN" 이라는 통념을 따라가다

선택 국내 UTM 장비 도입

- › SSL / IPsec VPN이 아주 제한된 방식만 지원
- › device · OS 의존성이 컸다

요구사항 우리가 실제로 필요했던 것

- › iOS · macOS · Windows · Android 전부 지원
- › MFA 필수
- › → UTM으로는 처음부터 불가능했다

글로벌 방화벽 벤더로 전환

— 주변 팀을 억지로 설득해서, 적잖은 비용을 들여

결과 그래도 안 됐다

- › SSL VPN 구성 → 모바일 디바이스 의존성 여전
- › 일부 영업장은 비용 때문에 구형 장비 잔존

그리고 보안 마감은 다가오고

- › 완전치 않은 채로 전사 적용을 밀어붙여야 했다

전사 VPN을 강행했고,

즉시 장애 → 전면 롤백

적용 → 현장 곳곳에서 접속 실패 → 당일 롤백

고치려 할수록 벽만 늘어났다

버전 올렸더니

- › 벤더가 상위 버전 위험성을 들어 지원 거부

SSL VPN 사양길

- › 벤더 향후 미지원 방향 — 미래가 없는 선택

IPsec 대안?

- › 설정 지옥, 제대로 구성 안 됨, Android 의존성 여전

AWS Verified Access

- › 검토 → 쉽지 않고 비용 압박이 거셌다

"처음 봤던 그것을 제대로 검증해보자."

비용도 안 드니, 트라이얼로 우리에게 맞는 도구인지 확인만 해보겠다고 했다. 2주는 너무 짧았다 — Twingate CEO에게 직접 "분명 도입할 거다, 한 달만 더 달라"고 요청했고, 받아들여졌다. 며칠을 그것만 붙들고 씨름한 끝에, 이게 정답이라는 걸 알았다.

무료 트라이얼



CEO 직접 연장 요청 · 수락



확신

Cloudflare 등 타사와 나란히 비교했다

동료와 경영진을 설득하려면 근거가 필요했다. 유사 기능 제품들을 같은 기준으로 비교했고, 우리 조직에는 Twingate가 가장 적합하다는 결론에 도달했다.

왜 우리에게 맞았나

01

SSO 연동

Okta로 통합 인증

02

무매뉴얼 UX

설명서 없이 쓰는 경험

03

Split tunneling

필요한 트래픽만

04

ISMS audit

심사 조건에 맞는 감사 기능

05

지속적 검증

IP가 아니라 사용자 · 인증 수단 · 장치 · 리소스 기준으로 매 접근을 검증

06

AWS 통합

인프라와 자연스럽게 결합

07

Seamless 로그인

끊김 없는 접속 경험

설득은 쉬웠다.
근거가 분명했으니까.

경영진 · 동료 설득



즉시 카드 결제



CEO에게 "기다려줘서 고맙다"

"물리장비도 없는데 어떻게 더 안전하다는 거지?"

결정의 근거를 이해하려면 Twingate가 쓴 기술을 봐야 한다. 어렵지 않다 — 일상의 비유로 하나씩 풀어보자.

컴포넌트



포트 0

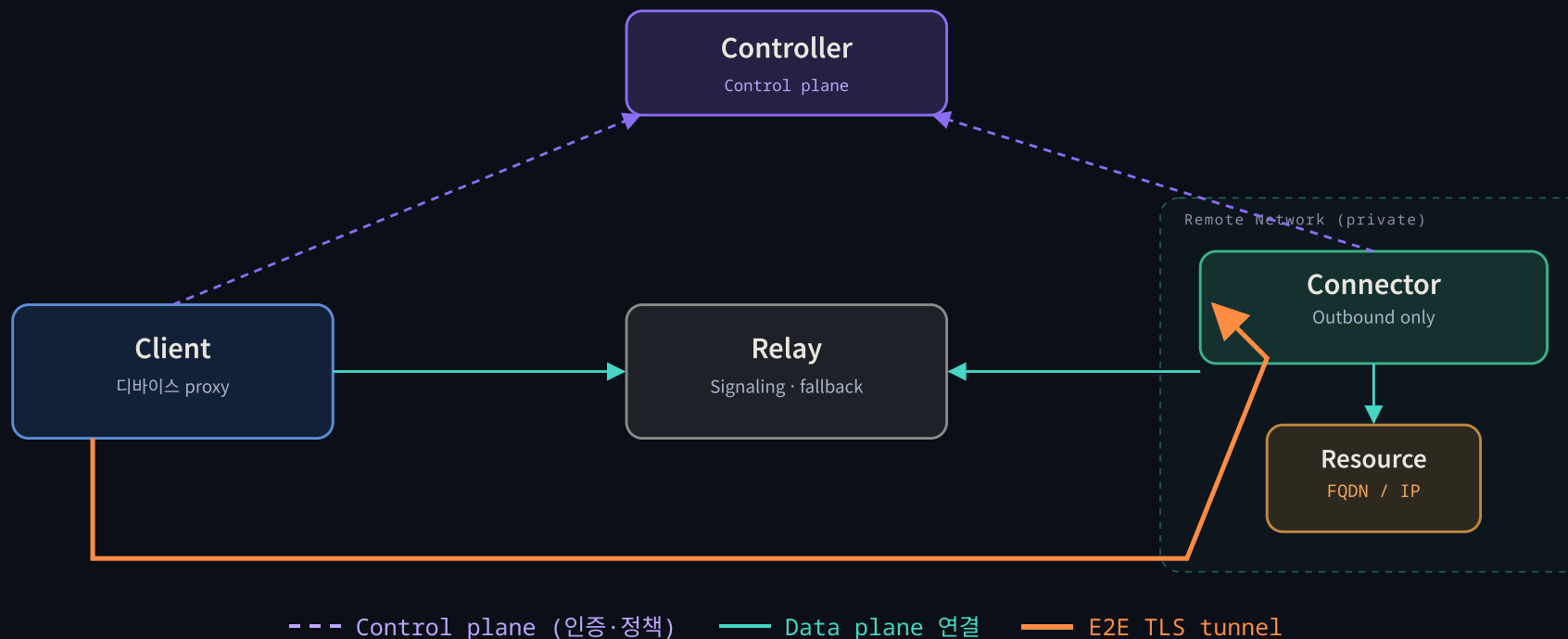


직접 연결



지속 검증

네 개의 조각이 나눠 맡는다



역할 분리가 핵심. **Controller**는 정책만, **Relay**는 신호·중계만, **Connector**는 사
내망에서 밖으로만. 실제 트래픽(주황)은 Twingate 서버를 안 지난다 —
Client↔Connector 직접.

✓ 하나가 뚫려도 단독으로 통과시킬 수 없다

인바운드 포트 0

“낮선 번호는 안 받아요. 제가 먼저 걸죠.

앞 그림의 **Connector**가 "Outbound only"인 이유. 사내망에서 **밖으로만** 연결을 거니, 외부에서 두드릴 포트 자체가 없다.

✓ 열린 문이 없으니, 털릴 문도 없다 — 공격 표면 0

위조 못 하는 출입 명단

“행사장 출입 명단에 주최 측 도장이 찍혀 있어요.
도장 없는 명단은 아무도 안 믿어요.

Client와 Connector는 각자 "어디에 연결해도 되는지"의 명단(allow list)을 받는데, 둘 다 같은 Controller가 서명한 것이어야 한다. 서명이 안 맞으면 연결 자체가 성립하지 않는다.

✓ 중간에서 명단을 위조해 끼어들 수 없다

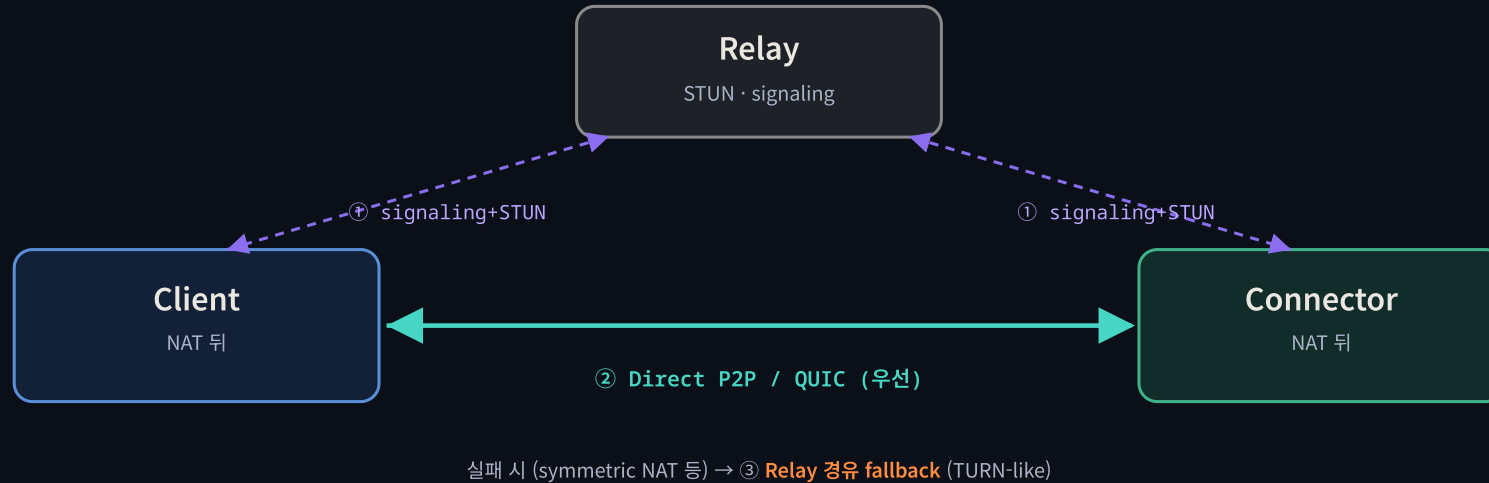
소개는 받지만, 대화는 둘이서

| “소개팅 주선자는 둘을 이어주고 빠져요. 대화는 둘이 직접.

앞 그림의 주황 굵은 선(E2E TLS)이 그것. **Relay**는 처음 한 번 신호만 거들고, 실제 트래픽은 Client ↔ Connector 직접이라 Twingate 서버를 안 지난다.

✓ 빠르고(지연 최소), 우리 트래픽이 SaaS를 안 지난다

서로의 진짜 주소 찾기



“둘 다 큰 건물 안에 있어요. **"나 몇 동 몇 호야"**를 먼저 알아야 직접 만날 수 있죠.

✓ 방화벽 뒤에 있어도 추가 포트 개방 없이 연결

이동해도 안 끊긴다 — QUIC

“통화 중에 Wi-Fi에서 LTE로 바뀌어도
전화가 안 끊기는 것 — 그런 느낌이에요.

Twingate는 전송에 QUIC(HTTP/3의 기반)을 쓴다. 연결이 한 번에 빠르게 맺어지고, IP가 바뀌어도(카페→사무실) 세션이 살아남는다. 최신 암호(TLS 1.3 이상)만 쓴다.

✓ 모바일·재택 환경에서 끊김 없는 접속

중계소는 상자 속을 못 본다

“직접 못 만나면 **중립 보관함**에 맡겨요.
택배 기사는 상자를 나르지만 — 안에 뭐가 든진 못 봐요.

직접(P2P) 연결이 안 되는 경우에만 **Relay**가 중계하는데, 트래픽은 양 끝에서 암호화돼 있어 **Relay**는 복호화할 수 없고, 저장하지도 않는다(zero-knowledge). 비밀 번호도 IdP에 위임해 Twingate가 안 갖는다.

✓ SaaS를 거쳐도 우리 데이터를 그들이 못 본다 (국외이전 방어)

매번 다시 묻는다

“건물에 한 번 들어왔다고 모든 방에 들어가지 못하죠.
방마다 다시 카드를 찍어야 해요.

기존 VPN은 "터널 안에 들어오면 신뢰"였다. ZTNA는 매 접근마다 누가(사용자) ·
무엇으로(인증수단) · 어떤 기기(장치) · 어디에(리소스)를 다시 확인한다. 신뢰의
단위가 네트워크가 아니라 **신원**이다.

✓ 한 곳이 뚫려도 옆으로 못 번진다 (측면 이동 차단)

20 ——— 그래서 — 우리는 이렇게 적용했다

개념을 우리 인프라에 얹기

여기서부터는 실제 우리 구성이다. ZTNA를 "도입했다"가 아니라, AWS 위에 코드로 어떻게 세우고 운영하는지.

신원부터 하나로



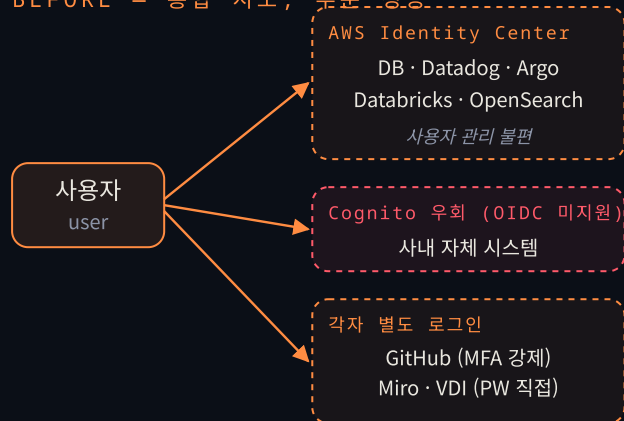
ECS로 다중화



정책은 코드로

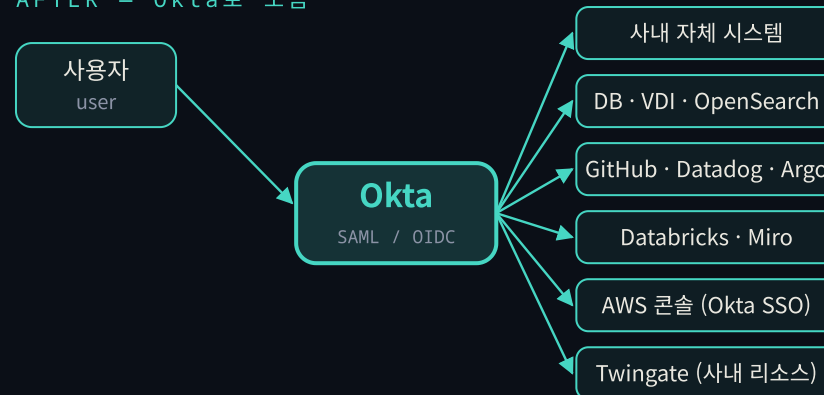
ZTNA를 엮기 전에, 신원이 먼저 하나여야 했다

BEFORE - 통합 시도, 부분 성공



→ Identity Center로
통합하려 했으나
→ 구조적으로 막힘
(OIDC · 사용자관리)
→ 결국 3갈래
관리 부담 누적

AFTER - Okta로 모음



AWS Identity Center로 통합을 시도했지만 **OIDC를 받지 못해** 사내 자체 시스템은 **Cognito**로 우회해야 했고, **사용자 관리 자체도 불편**했다. GitHub·Miro·VDI는 통합조차 못 들어와 결국 3갈래로 갈라졌다. → **Okta 한 곳**으로 모았다. 흩어져 있던 신원이 비로소 한 곳에 모이는 순간이었다.

✓ ZTNA는 "이 신원에 권한을 주자"로 자연스럽게 이어졌다

사내망 요원을 둘 세웠다



“문지기가 한 명이면 그 사람이 쓰러지면 끝.
서로 다른 건물에 두 명을 둡니다.

Connector를 **ECS Fargate**로 띄우되, 서로 다른 AZ에 2개 독립 서비스로 다중화.
둘 다 **private** 서브넷에서 밖으로만(egress-only) — '포트 0'의 실제 구현.

✓ 한쪽 장애·배포 중에도 접속이 끊기지 않는다

"누가 어디에" 를 코드로

```
# 리소스 39개 · 그룹 2개(Everyone/WorkSpaces)를 코드로 관리
resource "twingate_resource" "rds" {
  name      = "*.rds.amazonaws.com"
  protocols = { tcp = { policy = "RESTRICTED", ports = ["3306"] } } # MySQL만
  access_group { group_id = local.group_everyone_id }
}
```

✓ 리소스마다 필요한 포트만 — 최소권한이 기본값

접근 정책 = PR = 증거

“출입 권한을 바꿀 때 말로 부탁하지 않아요.
서류로 신청하고, 승인받고, 기록이 남죠.

접근 정책 변경은 콘솔 클릭이 아니라 코드 변경(PR) → 리뷰 → 승인으로 이뤄진다. 누가·언제·무엇을 바꿨는지가 git 이력에 그대로 남는다.

✓ 심사 때 따로 모으지 않아도, 운영하면 증거가 쌓인다

접속과 인증이 한 흐름이 됐다

“사원증 하나로 모든 문을 엽니다.
퇴사하면 그 카드 하나만 끄면 전부 닫혀요.

접속 측은 Twingate가, 인증 측은 Okta가 책임진다. 두 축이 만나는 지점은 단순하다 — Twingate 그룹 = Okta 그룹. 백오피스·DB·VDI·AWS 콘솔까지 같은 신원으로 들어가고, HR이 Okta에서 비활성화하면 Twingate 세션도, AWS 콘솔도, GitHub도 같은 순간에 닫힌다.

✓ 회수 누락이 사람의 손이 아니라 구조로 사라진다

한 번에 잡힌 세 가지

보안

공격 표면이 사라졌다

열린 포트 0 · 매 접근 지속 검증 · 한 곳 뚫려도 측면 이동 차단

경험

현장이 그냥 쓴다

매뉴얼 없이 로그인 · IP 바뀌어도 안 끊김 · 영업장 구형장비 의존 제거

운영

물리장비 0 · 정책은 코드

유지보수 부담 제거 · PR이 곧 증적 · 입퇴사 한 번에 반영

덤

심사도 수월해졌다

ISMS 접근통제(2.5·2.6)를 구조로 충족 — 증적이 운영의 부산물

"SaaS인데 끊기면 어쨌죠?"

Q 제어 평면이 죽으면?

- › 트래픽은 P2P 직접이라, 이미 맺은 세션은 영향이 작다
- › Connector를 2 AZ로 다중화 — 단일 장애점 제거
- › 신규 세션 수립만 영향 → 운영 연속성 계획으로 관리

Q 우리 트래픽을 SaaS가 보나?

- › P2P 직접 흐름 — Twingate 인프라 미경유가 기본
- › Relay 경유해도 복호화 불가·미저장(zero-knowledge)
- › 비밀번호는 IdP 위임 → Twingate가 안 가짐

정직하게, 함정과 한계

현황 자동 확장

- › 2 AZ 다중화 + 오토스케일링 정책 적용 중 — 네트워크 throughput 70% 시 scale out
- › 근거: 1 vCPU $\approx$ 500Mbps practical throughput (encryption overhead 포함)

규제 국외이전 소명?

- › 위탁·국외이전 고지는 필요
- › 계약상 DPA·표준계약조항(SCC) 적용으로 근거 확보

조화 망분리와 SaaS?

- › 망분리 정책과의 양립은 설명 부담이 있었다
- › 심사원에게 ZTNA 개념부터 이해시키는 과정 필요

ISMS는 목적이 아니라 제약조건이었다.

요구사항에서 출발했어야 했다.

TAKEAWAY 남길 한 문장

- › 컴플라이언스 체크박스가 아키텍처를 결정하게 두지 마라
- › "폐쇄망 + 물리 VPN"은 ISMS의 정답이 아니라 통념일 뿐이었다
- › 두 축으로 풀었다 — 안전한 접속(Twingate) · 안전한 인증(Okta)
- › 정답은 6개월 내내 눈앞에 있었다 — IP 경계가 아닌 Zero Trust

어려운 기술도, 쉽게

- ? 포트 0 = "내가 먼저 거는 콜백"
- ? P2P = "소개만 받고 대화는 둘이서"
- ? Relay = "안을 못 보는 택배 보관함"

— APPENDIX · 부록 —

근거는 전부 여기에

본 발표는 서사 중심으로 가볍게 갔습니다. 기술적 깊이·비교·출처는
이 부록에서 다룹니다. Q&A는 "부록 N번"으로 답하겠습니다.

A1 벤더 비교

A2 SSL VPN 사양길

A4 Twingate 아키텍처

A5 Okta SSO

A6 ISMS 매핑

A7 Terraform 운영

A9 트레이드오프

같은 기준으로 나란히 놓고 봤다

기준	국내 UTM 장비	글로벌 방화벽 벤더	AWS Verified Access	Cloudflare	Twingate
물리장비 불필요	×	×	○	○	○
전 OS 지원 iOS·Mac·Win·Android	△	△	○	○	○
MFA / SSO	제한적	부가구성	○	○	○
접근 모델	IP/터널	IP/터널	ZTNA	ZTNA	ZTNA
구매뉴얼 UX	×	×	△	△	○
운영 부담	높음	높음	중간	중간	낮음
비용 성격	장비+라이선스	장비+라이선스 ↑	사용량 과금	구독	구독
우리 조직 적합도	×	×	△	△	최적합

○ 충족 · △ 부분/조건부 · × 미충족. **UTM·방화벽은 IP 경계 모델**이라 멀티 디바이스 + MFA 요구를 처음부터 충족하지 못했다. ZTNA 3종 중 운영부담·UX·AWS 통합에서 Twingate가 우리 조직에 가장 맞았다.

"미래가 없는 선택"의 근거

FortiOS 7.6.3부터 SSL VPN tunnel mode가 IPsec VPN으로 대체되어 GUI·CLI에서 제거. 전 모델 적용, 이전 설정은 업그레이드 시 이관되지 않음. 2GB RAM 이하 모델은 web·tunnel mode 자체 제거.

FortiOS 7.6.3 Release Notes — SSL VPN tunnel mode no longer supported

docs.fortinet.com/document/fortigate/7.6.3/fortios-release-notes/173430/ssl-vpn-tunnel-mode-no-longer-supported

2GB RAM 모델 — SSL VPN (tunnel·web mode) 제거

docs.fortinet.com/document/fortigate/7.6.0/fortios-release-notes/877104/ssl-vpn-removed-from-2gb-ram-models-for-tunnel-and-web-mode

SSL VPN → IPsec VPN 마이그레이션 가이드 (7.6.3)

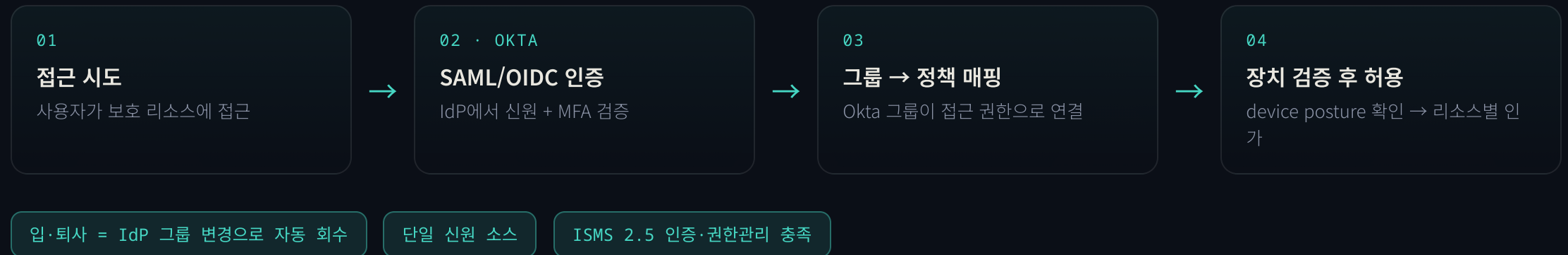
docs.fortinet.com/document/fortigate/7.6.0/new-features/155142/migration-from-ssl-vpn-tunnel-mode-to-ipsec-vpn-7-6-3

한 번 연결될 때 무슨 일이 일어나나

- 1 인증 — Client가 Controller에 인증 → 리소스별 **time-bound signed token** + Connector 정보 수령
- 2 신호 — Relay를 통해 양쪽이 signaling + STUN으로 **NAT 바깥 주소 교환**
- 3 터널 — Client ↔ Connector 간 **certificate-pinned end-to-end TLS tunnel** 수립 (P2P 우선, symmetric NAT 등 실패 시 Relay 경유 fallback)
- 4 해석·전달 — Connector가 **local DNS**로 FQDN 해석 후 사내 Resource로 forwarding

Controller는 data plane을 안 지난다. Twingate 인프라가 다운돼도 이미 맺은 터널의 트래픽은 Client↔Connector 직접이라 즉시 끊기지 않는다. 본편 12·15·16 그림 참조.

신원은 IdP가, 접근은 정책이



심사 기준에 ZTNA를 그대로 었다

통제항목	요지	구현 (ZTNA)
2.5 인증·권한관리	사용자 등록·해지, 권한 부여·변경·말소 절차 / 퇴직 시 지체 없이 회수	Okta(SAML/OIDC) + 그룹 정책. 입·퇴사 자동 회수
2.6.1 네트워크 접근	비인가 접근 통제, 네트워크 분리	inbound port 0, per-resource authorization
2.6.2 정보시스템 접근	접속 위치 제한, 특수권한 강화 인증, 미사용 계정 검토	device posture + 정책을 코드로 관리해 검토 자동화
2.6.6 원격접근	원격·재택 접근 통제	ZTNA 단일 경로로 일원화

출처: KISA ISMS-P 인증기준 안내서 (2022.4.22 정본), IT위키 2.5 / 2.6 접근통제 항목.

접근 정책 = PR 리뷰 = 증적

```
# 리소스 · 그룹 접근을 코드로 — provider: Twingate/twingate
resource "twingate_resource" "backoffice" {
  name      = "internal-backoffice"
  address   = "backoffice.internal"
  remote_network_id = twingate_remote_network.prod.id
  access_group {
    group_id = twingate_group."backoffice-admin".id # Okta 동기화
  }
}
```

실제 운영. 리소스 39개·그룹 2개를 코드로 관리, GitOps로 apply. PR 리뷰가 곧 변경 증적.

provider Twingate/twingate v4.2 · 본편 21~24 참조

완벽한 선택은 없다

의존성

SaaS control plane

- › 제어 평면 장애 시 신규 세션 수립 영향 범위
- › 가용성 SLA · 장애 시 운영 연속성 계획 필요

규제

개인정보 · 국외이전

- › 클라우드 사업자 통제 소명 / 위탁·국외이전 고지
- › data plane은 자사 경유라도 메타데이터 처리 범위 확인

조화

망분리와 SaaS

- › 망분리 정책과 SaaS 기반 접근통제의 양립 설명 부담
- › 심사원에게 ZTNA 개념을 이해시키는 과정 필요

상쇄

그럼에도 선택한 이유

- › 물리장비 운영부담·매몰비용 제거
- › 코드화된 정책 = 재현 가능한 증적